

Daily Vulnerability Report - 2026-09-07

Window (UTC): 2026-09-07T00:00 to 2026-09-08T00:00 | Sources: NVD, CISA KEV, FIRST EPSS | Generated 2026-09-17 05:48:27 UTC

Total	KEV (exploited)	Critical	High	Medium	Low	Unscored	Watchlist
357	18	36	98	145	45	33	88

P1 - Act now (KEV / high EPSS)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75650	10.0	CRIT	Yes	0.021	adobe:commerce, adobe:commerce_b2b, adobe:magento	Adobe Commerce is affected by an Improper Neutralization of Special Elements Used in a Template Engine vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2025-25249			Yes	0.024	fortinet:multiple products	Fortinet FortiOS, FortiSwitchManager, and FortiSASE contain a heap-based buffer overflow vulnerability that allows an attacker to execute unauthorized code or commands via specially crafted packets.
CVE-2026-19490			Yes	0.056	citrix:netscaler	Citrix NetScaler ADC and NetScaler Gateway contain an authentication-bypass vulnerability involving an alternate path or channel. When the NetScaler appliance is configured as an AAA virtual server or as a Gateway (SSL VPN, ICA Proxy, CVPN, or RDP Proxy), an unauthenticated remote threat actor may be able to bypass authentication.
CVE-2026-20079			Yes	0.758	cisco:secure firewall management center (fmc) and security cloud control (scc) firewall management	Cisco Secure Firewall Management Center (FMC) Software and Cisco Security Cloud Control (SCC) Firewall Management contain an authentication Bypass using an alternate path or channel vulnerability that could allow an unauthenticated, remote attacker to bypass authentication and execute script files on an affected device to obtain root access to the underlying operating system.
CVE-2026-42016			Yes	0.009	jfrog:artifactory	JBFrog Artifactory contains an incorrect authorization vulnerability that leads to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.
CVE-2026-42018			Yes	0.009	jfrog:artifactory	JBFrog Artifactory contains an improper authentication vulnerability that could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.
CVE-2026-58704			Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-67277			Yes	0.009	mikrotik:routeros	MikroTik RouterOS contains a missing authentication for critical function vulnerability which allows kernel memory disclosure and denial of service in the btest service.
CVE-2026-76460			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81963			Yes	0.006	microsoft:windows	Microsoft Windows Update Stack contains a link following vulnerability that allows a local attacker to escalate privileges locally up to SYSTEM.
CVE-2026-84869			Yes	0.007	connectwise:screenconnect	ConnectWise ScreenConnect contains both an improper privilege management and missing authorization vulnerability that may allow an attacker to transfer and execute files through an active remote session without authorization or host confirmation.
CVE-2026-85706			Yes	0.12	gitlab:community edition and enterprise edition	GitLab Community Edition and Enterprise Edition contains a path traversal vulnerability that allows an unauthenticated user to read arbitrary files due to an improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-85880			Yes	0.006	microsoft:windows	Microsoft Windows Advanced Local Procedure Call contains a heap-based buffer overflow vulnerability that allows an attacker to elevate privileges locally.
CVE-2026-86060			Yes	0.011	mikrotik:routeros	MikroTik RouterOS contains an improper neutralization of argument delimiters in a command vulnerability which allows an attacker to change the trusted RouterOS policy mask, leading to privilege escalation.
CVE-2026-86218			Yes	0.007	n-able:n-central	N-able N-central contains a static code injection vulnerability that could allow for pre-authentication remote code execution.
CVE-2026-87491			Yes	0.01	google:chromium v8	Google Chromium V8 contains an out of bounds write vulnerability that allows a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. This vulnerability could affect multiple web browsers that utilize Chromium, including, but not limited to, Google Chrome, Microsoft Edge, and Opera.
CVE-2026-87886			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-43997	10.0	CRIT		0.01	vm2_project:vm2	vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.0, it is possible to obtain the host Object. There are various ways to use the host Object, to escape the sandbox, one example would be using HostObject.getOwnPropertySymbols to obtain Symbol(nodejs.util.inspect.custom). This vulnerability is fixed in 3.11.0.
CVE-2026-44005	10.0	CRIT		0.008	vm2_project:vm2	vm2 is an open source vm/sandbox for Node.js. From 3.9.6 to 3.10.5, vm2's bridge exposes mutable proxies for real host-realm intrinsic prototypes and then forwards sandbox writes into the underlying host objects with otherReflectSet() and otherReflectDefineProperty(), which lets attacker-controlled JavaScript running in a default VM or inherited NodeVM mutate shared host Object.prototype, Array.prototype, and Func...
CVE-2026-43999	9.9	CRIT		0.01	vm2_project:vm2	vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.0, NodeVM's builtin allowlist can be bypassed when the module builtin is allowed (including via the '*' wildcard). The module builtin exposes Node's Module._load(), which loads any module by name directly in the host context, completely bypassing vm2's builtin restriction. This allows sandboxed code to load excluded builtins like child_process and achieve...
CVE-2025-61140	9.8	CRIT		0.004	dchester:jsonpath	The value function in jsonpath 1.1.1 lib/index.js is vulnerable to Prototype Pollution.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-11613	9.8	CRIT		0.005		The Divi Ajax Filter plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 5.1.2 via the 'custom_loop_template' parameter parameter. This makes it possible for unauthenticated attackers to include and execute arbitrary .php files on the server, allowing the execution of any PHP code in those files. This can be used to bypass access controls, obtain sensitive data, or achi...
CVE-2026-18922	9.8	CRIT		0.006		A flaw was found in 389 Directory Server. During SASL PLAIN authentication, a stale identity carried in a Cyrus SASL auxiliary property from a prior failed bind attempt can be installed on a connection following a subsequent, unrelated successful bind, regardless of which SASL mechanism completes that second bind. An attacker can send a SASL PLAIN bind as cn=Directory Manager with an incorrect password, then compl...
CVE-2026-44009	9.8	CRIT		0.008	vm2_project:vm2	vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.2, This vulnerability is fixed in 3.11.2.
CVE-2026-45411	9.8	CRIT		0.006	vm2_project:vm2	vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.3, it is possible to catch a host exception using the yield* expression inside an async generator. When the generator is closed using the return function, the value is awaited on and exceptions thrown in the then call will be caught by the runtime and passed to the yield* iterator as the next value. This allows attackers to write code which can escape fro...
CVE-2026-64068	9.8	CRIT		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfs: Fix missing locking around retry adding new subreqs Fix netfs_retry_read_subrequests() and netfs_retry_write_stream() to take the appropriate lock when adding extra subrequests into stream->subrequests.
CVE-2026-76578	9.8	CRIT		0.005		A flaw was found in FreeIPA. The self-managed OTP token ACI does not require authentication and does not restrict which attributes may be added alongside the token entry. An unauthenticated LDAP client can exploit this, combined with a related flaw in the underlying directory server's ACI evaluation (tracked separately), to create an arbitrary attacker-controlled Kerberos principal and have it added to the adminis...
CVE-2026-7861	9.8	CRIT		0.003		Deserialization of untrusted data vulnerability in Next4Biz Information Technologies Inc. CSM (Customer Service Management) allows Code Injection. This issue affects CSM (Customer Service Management): before 8.0.3.
CVE-2026-80129	9.8	CRIT		0.004	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.
CVE-2026-80131	9.8	CRIT		0.005	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.
CVE-2026-84238	9.8	CRIT		0.003		Unauthenticated Broken Access Control in YITH Request a Quote for WooCommerce Premium < 4.46.0 versions.
CVE-2026-84834	9.8	CRIT		0.003		Unauthenticated PHP Object Injection in JobSearch <= 3.2.0 versions.
CVE-2026-86478	9.8	CRIT		0.004		In JetBrains YouTrack before 2025.3.161254, 2026.1.14042 improper authentication in YouTrack Helpdesk allowed unauthenticated account takeover via a self-asserted email address
CVE-2026-86480	9.8	CRIT		0.003		In JetBrains Hub before 2026.2.52442 an unauthenticated attacker could register a trusted service and gain superuser privileges

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-12543	9.6	CRIT		0.014	redhat:build_of_apache_camel, redhat:data_grid, redhat:fuse, redhat:jboss_enterprise_application_platform, redhat:jboss_	A flaw was found in the Undertow HTTP server core, which is used in WildFly, JBoss EAP, and other Java applications. The Undertow library fails to properly validate the Host header in incoming HTTP requests. As a result, requests containing malformed or malicious Host headers are processed without rejection, enabling attackers to poison caches, perform internal network scans, or hijack user sessions.
CVE-2026-33211	9.6	CRIT		0.006	linuxfoundation:tekton_pipelines	Tekton Pipelines project provides k8s-style resources for declaring CI/CD-style pipelines. Starting in version 1.0.0 and prior to versions 1.0.1, 1.3.3, 1.6.1, 1.9.2, and 1.10.2, the Tekton Pipelines git resolver is vulnerable to path traversal via the `pathInRepo` parameter. A tenant with permission to create `ResolutionRequests` (e.g. by creating `TaskRuns` or `PipelineRuns` that use the git resolver) can read a...
CVE-2026-42880	9.6	CRIT		0.005	argoproj:argo_cd	Argo CD is a declarative, GitOps continuous delivery tool for Kubernetes. From versions 3.2.0 to before 3.2.11 and 3.3.0 to before 3.3.9, there is a missing authorization and data-masking gap in Argo CD's ServerSideDiff endpoint that allows an attacker with read-only access to extract plaintext Kubernetes Secret data from etcd via the Kubernetes API server's Server-Side Apply dry-run mechanism. This issue has been...
CVE-2026-54210	9.5	CRIT		0.005		Tobit Laboratories AG TeamDavid's Webbox application implements various file upload functionalities that are vulnerable to a buffer overflow condition. By specifying an excessively long filename in a file upload request, an unauthenticated attacker can trigger a crash of the server, resulting in a denial of service. Depending on the stack state or if a stack canary can be disclosed through another vulnerabi...
CVE-2026-54211	9.5	CRIT		0.004		Tobit Laboratories AG TeamDavid's Webbox application's endpoint "/serverClient_close.html" is vulnerable to a buffer overflow vulnerability in multiple form data parameters. By submitting excessively long values in these parameters, an authenticated attacker can trigger a server crash, resulting in denial of service. Depending on the stack state or if a stack canary can be disclosed through another vulnerabi...
CVE-2026-54212	9.5	CRIT		0.005		Tobit Laboratories AG TeamDavid's Webbox application implements an API endpoint that is vulnerable to a buffer overflow condition. By submitting a specially crafted JSON body, such as one that is at least 8 characters long and begins with a number, an unauthenticated attacker can cause the server to crash, resulting in denial of service. Depending on the stack state or if a stack canary can be disclosed throu...
CVE-2026-61410	9.4	CRIT		0.013	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains a Missing Authorization vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution. This vulnerability is considered critical because it allows an attacker to execute commands remotely on a target system by sending a spe...
CVE-2026-6223	9.4	CRIT		0.004		Improper restriction of excessive authentication attempts vulnerability in Bahçelievler Municipality BiHayat App allows Authentication Bypass. This issue affects BiHayat App: from 2.1.7 through 07092026. NOTE: The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-16876	9.3	CRIT		0.003		An authentication bypass vulnerability exists in the WebGUI of Series UNIVERGE IX-R/IX-V. A user could bypass authentication and execute arbitrary CLI commands by tampering with WebGUI messages and sending them to the device via internet.
CVE-2026-80238	9.3	CRIT		0.001	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Execution with Unnecessary Privileges vulnerability. An unauthenticated attacker with local access could potentially exploit this vulnerability, leading to Protection mechanism bypass. This vulnerability is considered critical because a low-privileged operator with SSH access to the SCG host c...
CVE-2026-86296	9.3	CRIT		0.013		A vulnerability was determined in D-Link DIR-822A A_101. This vulnerability affects the function strcpy of the file udhcpd/serverpacket.c of the component udhcpd. This manipulation causes stack-based buffer overflow. The attack is possible to be carried out remotely. The exploit has been publicly disclosed and may be utilized.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86543	9.3	CRIT		0.004		knowns versions before 0.30.0 serve the management API without authentication on all network interfaces by default, with no password required on fresh installations. Attackers can access the unauthenticated /api/tunnel/start endpoint to provision a public tunnel and republish the API at a publicly accessible address.
CVE-2026-54203	9.2	CRIT		0.003		Memory Leak to an Unauthorized Actor vulnerability in Tobit Laboratories AG TeamDavid's Webbox allows reading of sensitive information. When accessing the URL "/.well-known/mta-sts.", the application responds with memory. By repeatedly requesting this endpoint, an attacker can access sensitive information, including user passwords. Exploitation does not require authentication. This issue affects TeamDavid befo...
CVE-2026-54213	9.2	CRIT		0.006		Tobit Laboratories AG TeamDavid's Webbox application exposes a functionality that allows the server to be shut down when a specific endpoint (/internalRestart) is accessed. This endpoint is accessible to unauthenticated users over the public Internet. Instead of "restarting", the server shuts completely down. As a result, a remote attacker can trigger a persistent denial of service by shutting down the web se...
CVE-2026-86426	9.2	CRIT		0.014		LibreNMS before 26.8.0 contains an authentication bypass vulnerability in the REST API that allows unauthenticated attackers to access protected endpoints by sending numeric values instead of string tokens. Attackers can exploit MySQL type coercion by sending small integers like 0 through 9 to match token hashes, gaining access to API functionality including device credentials and administrative features that enab...
CVE-2026-44007	9.1	CRIT		0.01	vm2_project:vm2	vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.1, when a NodeVM is created with nesting: true, sandbox code can unconditionally require('vm2') regardless of the outer VM's require configuration — including require: false. With access to vm2, the sandbox constructs a new inner NodeVM with its own unrestricted require settings and executes arbitrary OS commands on the host. Any application that runs unt...
CVE-2026-56015	9.1	CRIT		0.007		Net::IP::LPM versions before 1.11 for Perl allow a heap out-of-bounds read via an unbounded prefix length. add() passes the prefix string to the trie builder addPrefixToTrie() without checking it against the address width. addPrefixToTrie() then walks the prefix buffer by prefix_length bits, reading prefix[byte] for byte up to prefix_len/8, where prefix is the 4-byte (IPv4) or 16-byte (IPv6) packed address. A pr...
CVE-2026-80164	9.1	CRIT		0.002	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Certificate Validation vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to unauthorized access.
CVE-2025-15467	8.8	HIGH		0.482	openssl:openssl	Issue summary: Parsing CMS AuthEnvelopedData or EnvelopedData message with maliciously crafted AEAD parameters can trigger a stack buffer overflow. Impact summary: A stack buffer overflow may lead to a crash, causing Denial of Service, or potentially remote code execution. When parsing CMS (Auth)EnvelopedData structures that use AEAD ciphers such as AES-GCM, the IV (Initialization Vector) encoded in the ASN.1 pa...
CVE-2026-2670	7.3	HIGH		0.123		A vulnerability was identified in Advantech WISE-6610-NB, WISE-6610-EB, WISE-6610-TB, WISE-6610-JB, WISE-6610-CB, WISE-6610-EL-NB, WISE-6610-EL-EB, WISE-6610-EL-TB, WISE-6610-EL-JB, WISE-6610-EL-CB, WISE-6610P-DEA, WISE-6610P-DNA and WISE-6610P-DTA 1.2.1_20251110. Affected is an unknown function of the file /cgi-bin/luci/admin/openvpn_apply of the component Background Management. Such manipulation of the argument ...

Watchlist matches (other priorities)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-43391	8.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: nsfs: tighten permission checks for handle opening Even privileged services should not necessarily be able to see other privileged service's namespaces so they can't leak information to each other. Use may_see_all_namespaces() helper that centralizes this policy until the nstree adapts.
CVE-2026-80724	8.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: ptp: vmclock: prevent read-only mappings from becoming writable vmclock_miscdev_mmap() rejects writable mappings of the shared vmclock ABI page with -EROFS, but leaves VM_MAYWRITE set. Userspace can map the page read-only and then upgrade it to writable with mprotect(), after which the guest can corrupt the host-written timekeeping data (sequen...
CVE-2026-43998	8.5	HIGH		0.007	vm2_project:vm2	vm2 is an open source vm/sandbox for Node.js. In 3.10.5, NodeVM's require.root path restriction can be bypassed using filesystem symlinks, allowing sandboxed code to load modules from outside the allowed root directory in host context. Because path validation uses path.resolve() (which does not dereference symlinks) but module loading uses Node's native require() (which does), an attacker can load arbitrary host-r...
CVE-2026-54202	8.5	HIGH		0.003		Tobit Laboratories AG TeamDavid's Webbox is vulnerable to a path traversal vulnerability in the archive creation functionality. Because the archive path is user-controlled and insufficiently validated, an attacker can manipulate the input to traverse directories. This allows the creation of folders in arbitrary locations, including sensitive directories such as C:\Windows or for different users. This issue a...
CVE-2026-54208	8.5	HIGH		0.004		Tobit Laboratories AG TeamDavid's Webbox application is vulnerable to arbitrary file write, allowing an unauthenticated attacker to create or write into existing files on the server with attacker-controlled content. This is possible because user input is written directly to files without proper validation or restriction on file types. As a result, an attacker can create files (e.g., .htm), containing maliciou...
CVE-2026-84226	8.5	HIGH		0.001		OpenVPN version 2.5.0 through 2.6.22 and 2.7_alpha1 through 2.7.6 on Windows allows local authenticated users to perform a binary planting attack during network configuration steps
CVE-2026-80753	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: ovpn: run deferred work on a module-owned workqueue ovpn queues several work items whose callbacks execute module text. These works currently run on the global system workqueues, so module exit has no driver-owned drain point that guarantees the callbacks have fully returned before the module text can be freed. Object references protect the obj...
CVE-2026-23459	8.2	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ip_tunnel: adapt iptunnel_xmit_stats() to NETDEV_PCPU_STAT_DSTATS Blamed commits forgot that vxlan/geneve use udp_tunnel[6]_xmit_skb() which call iptunnel_xmit_stats(). iptunnel_xmit_stats() was assuming tunnels were only using NETDEV_PCPU_STAT_TSTATS. @syncp offset in pcpu_sw_netstats and pcpu_dstats is different. 32bit kernels would either ...
CVE-2026-23745	8.2	HIGH		0.004	isaacs:tar	node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.
CVE-2026-24842	8.2	HIGH		0.006	isaacs:tar	node-tar, a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fi...
CVE-2026-82586	8.2	HIGH		0.003		Improper Protection of Alternate Path vulnerability in ash-project ash_lua allows a user-supplied Lua script to read attributes that are not on the exposed-field allow-list. AshLua exposes Ash resources to Lua scripts, gated by a manifest declaring which fields are exposed. The read action's operation aggregate path in AshLua.Runtime took the field name straight from the Lua call and resolved it with only String....

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-43009	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: bpf: Fix incorrect pruning due to atomic fetch precision tracking When backtrack_insn encounters a BPF_STX instruction with BPF_ATOMIC and BPF_FETCH, the src register (or r0 for BPF_CMPXCHG) also acts as a destination, thus receiving the old value from the memory location. The current backtracking logic does not account for this. It treats atom...
CVE-2026-84256	7.7	HIGH		0.004		An argument parsing issue in OpenVPN 2.1_rc10 through 2.6.22 and 2.7_alpha1 through 2.7.6 on Windows allows remote authenticated users to execute arbitrary commands via a crafted certificate subject
CVE-2025-69534	7.5	HIGH		0.006	python-markdown:markdown	Python-Markdown version 3.8 contain a vulnerability where malformed HTML-like sequences can cause html.parser.HTMLParser to raise an unhandled AssertionError during Markdown parsing. Because Python-Markdown does not catch this exception, any application that processes attacker-controlled Markdown may crash. This enables remote, unauthenticated Denial of Service in web applications, documentation systems, CI/CD pip...
CVE-2026-78254	7.4	HIGH		0.005	apache:ant	The ftp and scp tasks of Apache Ant can download files from a remote server. A malicious server can provide relative paths that allow it to write outside of the dedicated target directory for the download, making it possible to overwrite files of the attacker's choice using the permissions of the user running Ant in versions prior to Ant 1.10.18. In order to exploit this vulnerability, the server would either...
CVE-2026-78325	6.9	MEDI		0.001		Cross-site scripting in the Evernote and Google Keep note importers in Standard Notes for Android through 3.201.24 allows an attacker to execute arbitrary JavaScript in the application context when a victim imports a crafted .enex or Google Keep HTML file, leading to theft of encryption keys and note data, and arbitrary invocation of native device APIs.
CVE-2026-86431	6.9	MEDI		0.002	thephpleague:commonmark	league/commonmark (thephpleague/commonmark) versions >= 2.7.0 and < 2.9.1 contain a cross-site scripting vulnerability in the AttributesExtension. Prefixing an attribute name with a single U+000C form feed byte (e.g. {x0Conclick="alert(1)"} bypasses the AttributesHelper::filterAttributes() "on*" event-handler filter because PHP's trim() does not strip U+000C, causing the attribute to be written verbatim into the...
CVE-2026-18796	6.8	MEDI		0.001		Any application that uses external QSPI flash for encrypted XIP on nRF5340 and relies on that encryption for confidentiality and/or integrity of the externally stored code. No specific nRF Connect SDK version is the root cause; the weakness is in the on-the-fly decryption scheme.
CVE-2026-86332	6.5	MEDI		0.002		A flaw was found in odh-dashboard in Red Hat OpenShift AI. The backend-for-frontend route GET /api/nim-serving/:nimResource reads Kubernetes Secrets using the dashboard service account and returns the full Secret object, including .data, without an authorization check. Any authenticated dashboard user can retrieve the cluster NVIDIA NGC API key Secret (apiKeySecret) and the NIM image pull secret (nimPullSecret). C...
CVE-2026-86314	6.2	MEDI		0.001		Integer overflow in the source-bounds check in Memory::init() (src/runtime/Memory.cpp) in Samsung walrus on all platforms allows a remote attacker to cause an out-of-bounds heap read and denial of service via a crafted WebAssembly module in which a 32-bit unsigned addition wraps around and bypasses the bounds check. This issue affects Walrus: ff3bf5ff5c4878f8e5572c9593d303f6bc997443.
CVE-2026-86315	6.2	MEDI		0.001		An out-of-bounds write caused by numeric truncation Samsung Open Source Escargot on Linux x86-64 allows an attacker who can supply JavaScript for execution to corrupt native memory and crash the host process via a crafted class definition whose instance initialization entry count exceeds UINT16_MAX. This issue affects Escargot: 5dc93606abd42b859045add05d704a038e197359.
CVE-2026-78221	5.9	MEDI		0.001		An incorrect buffer size calculation in the Windows Interactive Service in OpenVPN 2.7_alpha1 through 2.7.6 allows local authenticated users to cause memory corruption or disclose sensitive information via crafted NRPT inputs.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78043	5.6	MEDI		0.002		The Windows Interactive Service in OpenVPN 2.7_alpha1 through 2.7.6 allows local authenticated users to bypass the trusted configuration directory constraint and load arbitrary configuration files via specially crafted paths
CVE-2026-81830	5.6	MEDI		0.001		The Windows interactive service in OpenVPN 2.4.0 through 2.6.22 allows local authenticated users to bypass the trusted configuration directory constraint via incorrect file path validation
CVE-2025-21817	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: block: mark GFP_NOIO around sysfs ->store() sysfs ->store is called with queue freezed, meantime we have several ->store() callbacks(update_nr_requests, wbt, scheduler) to allocate memory with GFP_KERNEL which may run into direct reclaim code path, then potential deadlock can be caused. Fix the issue by marking NOIO around sysfs ->store()
CVE-2025-22108	5.5	MEDI		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: bnxt_en: Mask the bd_cnt field in the TX BD properly The bd_cnt field in the TX BD specifies the total number of BDs for the TX packet. The bd_cnt field has 5 bits and the maximum number supported is 32 with the value 0. CONFIG_MAX_SKB_FRAGS can be modified and the total number of SKB fragments can approach or exceed the maximum supported by t...
CVE-2025-22127	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: f2fs: fix potential deadlock in prepare_compress_overwrite() Jan Prusakowski reported a kernel hang issue as below: When running xfstests on linux-next kernel (6.14.0-rc3, 6.12) I encountered a problem in generic/475 test where fsstress process gets blocked in __f2fs_write_data_pages() and the test hangs. The options I used are: MKFS_OPTIONS ...
CVE-2025-38205	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: Avoid divide by zero by initializing dummy pitch to 1 [Why] If the dummy values in `populate_dummy_dml_surface_cfg()` aren't updated then they can lead to a divide by zero in downstream callers like CalculateVMAndRowBytes() [How] Initialize dummy value to a value to avoid divide by zero.
CVE-2025-38621	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: md: make rdev_addable usable for rcu mode Our testcase trigger panic: BUG: kernel NULL pointer dereference, address: 00000000000000e0 ... Oops: Oops: 0000 [#1] SMP NOPTI CPU: 2 UID: 0 PID: 85 Comm: kworker/2:1 Not tainted 6.16.0+ #94 PREEMPT(none) Hardware name: QEMU Standard PC (i440FX + PIIX, 1996), BIOS 1.16.1-2.fc37 04/01/2014 Workqueue: md...
CVE-2026-53102	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: Fix memory leak after mt76_connac_mcu_alloc_sta_req() mt76_connac_mcu_alloc_sta_req() allocates an skb which is expected to be freed eventually by mt76_mcu_skb_send_msg(). However, currently if an intermediate function fails before sending, the allocated skb is leaked. Specifically, mt76_connac_mcu_sta_wed_update() and mt76_connac_m...
CVE-2026-53113	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: fix memory leaks in beacon template setup The functions ath11k_mac_setup_bcn_tmpl_ema() and ath11k_mac_setup_bcn_tmpl_mbssid() allocate memory for beacon templates but fail to free it when parameter setup returns an error. Since beacon templates must be released during normal execution, they must also be released in the error hand...
CVE-2026-53313	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: Avoid NULL dereference in dc_dmub_srv error paths In dc_dmub_srv_log_diagnostic_data() and dc_dmub_srv_enable_dpia_trace(). Both functions check: if (!dc_dmub_srv !dc_dmub_srv->dmub) and then call DC_LOG_ERROR() inside that block. DC_LOG_ERROR() uses dc_dmub_srv->ctx internally. So if dc_dmub_srv is NULL, the logging it...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86260	5.5	MEDI		0.004		A security flaw has been discovered in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. The affected element is the function modifyPassWord of the file ssm_pro/src/main/java/cn/sfturing/web/CommonUserController.java of the component Password Recovery. Performing a manipulation results in unverified password change. Remote exploitation of the attack is possible. The exploit has been released to t...
CVE-2026-86261	5.5	MEDI		0.004		A weakness has been identified in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. The impacted element is an unknown function of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Controller. Executing a manipulation of the argument userIdentf can lead to authorization bypass. The attack can be executed remotely. The exploit has been made available to the ...
CVE-2026-86262	5.5	MEDI		0.004		A security vulnerability has been detected in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. This affects the function updateOrderSta1/updateOrderdiseaseInfo of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Handler. The manipulation of the argument userID/id leads to authorization bypass. The attack is possible to be carried out remotely. The exploi...
CVE-2026-86263	5.5	MEDI		0.004		A vulnerability was detected in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. This impacts the function orderRecordsService.cancelOrder of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Cancellation. The manipulation of the argument ID results in authorization bypass. The attack may be performed from remote. The exploit is now public and may be used...
CVE-2026-86273	5.5	MEDI		0.003		A weakness has been identified in projeto-siga siga up to 11.1.1. Affected by this issue is the function DownloadExterno.getUrl of the file sigaex/src/main/java/br/gov/jfrj/siga/vraptor/ExUtilController.java of the component HTML-to-PDF Endpoint. This manipulation of the argument html causes server-side request forgery. The attack may be initiated remotely. The exploit has been made available to the public and cou...
CVE-2026-86274	5.5	MEDI		0.004		A security vulnerability has been detected in projeto-siga siga up to 11.0.2.10/11.0.2.13/11.1.1. This affects the function ExAutenticacaoController.autenticar of the file sigaex/src/main/java/br/gov/jfrj/siga/vraptor/ExAutenticacaoController.java of the component Authentication Flow. Such manipulation of the argument cod/jwt leads to missing authorization. The attack may be launched remotely. The exploit has been...
CVE-2026-86282	5.5	MEDI		0.003		A weakness has been identified in jaychouchannel Tourism-Management-System up to 8122bf020d91199eddf3ee02d1632a70a9a132. Affected is an unknown function of the file travel/src/main/java/com/controller/CommonController.java of the component CommonDao. Executing a manipulation of the argument table/column/xColumn/yColumn can lead to sql injection. The attack can be launched remotely. The exploit has been made avai...
CVE-2026-86284	5.5	MEDI		0.003		A security vulnerability has been detected in jaychouchannel Tourism-Management-System up to 8122bf020d91199eddf3ee02d1632a70a9a132. Affected by this vulnerability is the function getOption of the file travel/src/main/java/com/controller/CommonController.java. The manipulation of the argument tableName/columnName leads to information disclosure. The attack may be initiated remotely. The exploit has been disclose...
CVE-2026-86318	5.5	MEDI		0.004		A flaw has been found in java-json-tools json-patch up to 1.13. Affected is the function JsonMergePatch.fromJson of the file JsonMergePatchDeserializer.java. Executing a manipulation can lead to stack-based buffer overflow. The attack may be performed from remote. The exploit has been published and may be used. The project was informed of the problem early through an issue report but has not responded yet.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86319	5.5	MEDI		0.004		A vulnerability has been found in java-json-tools json-patch up to 1.13. Affected by this vulnerability is the function JsonPatch.apply of the file src/main/java/com/github/fge/jsonpatch/JsonPatch.java of the component Patch Operation Handler. The manipulation leads to resource consumption. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The project was...
CVE-2026-86321	5.5	MEDI		0.004		A vulnerability was found in java-json-tools jackson-coreutils 2.0. Affected by this issue is the function JsonLoader.fromURL of the file src/main/java/com/github/fge/jackson/JsonLoader.java of the component URL Validation. The manipulation results in server-side request forgery. It is possible to launch the attack remotely. The exploit has been made public and could be used. The project was informed of the proble...
CVE-2026-54217	5.3	MEDI		0.003		Tobit Laboratories AG TeamDavid's Webbox application is vulnerable to a stored XSS vulnerability. An attacker can send an email containing malicious JavaScript code. When a user accesses the email, the stored cross-site scripting is triggered. This issue affects TeamDavid before Rollout 528. Starting with Rollout 528 (June 30, 2026), the affected functionality is disabled by default and the vulnerabilities are ...
CVE-2026-86440	5.1	MEDI		0.001	misp-project:misp	Affected versions of MISP insufficiently validate URLs used by dashboard widgets, particularly the Button widget. The widget's URL is stored configuration controlled by a user. The previous renderer considered a URL safe if it appeared relative or if its parsed hostname matched the configured MISP hostname. That logic failed to reject dangerous schemes and URL forms that browsers normalize differently from PHP's...
CVE-2026-86503	3.3	LOW		0.001		In JetBrains IntelliJ IDEA before 2026.2.2 opening an untrusted project could trigger SSRF via Kubernetes spec-source URL fetching
CVE-2026-81738	2.3	LOW		0.003		OpenVPN 2.5.0 through 2.7.6 on Windows using the tap-windows6 driver allows attackers to trigger an out-of-bounds write via crafted DOMAIN-SEARCH entries
CVE-2026-86441	2.3	LOW		0.002	misp-project:misp	Affected versions of MISP contain inconsistent authorization checks across dashboard widgets that display organisation information. Several organisation-related widgets did not honor Security.hide_organisation_index_from_users. As a result, authenticated users without the perm_sharing_group permission could enumerate organisations even though the normal organisation index was intentionally hidden from them. Th...
CVE-2026-86264	2.1	LOW		0.003		A flaw has been found in sfturing ssm_pro up to 627f426331da8086ce8fff2017d65b1ddef384f8. Affected is an unknown function of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Endpoint. This manipulation of the argument hospitalName/officesName/doctorName causes cross site scripting. It is possible to initiate the attack remotely. The exploit has been published and may be us...
CVE-2026-82312	1.8	LOW		0.001		OpenVPN 2.0.0 through 2.6.22 and 2.7_alpha1 through 2.7.6 on Windows allows local authenticated users to cause a denial of service via a NULL DACL on named IPC objects
CVE-2026-86422	1.0	LOW		0.001	imagemagick:imagemagick	ImageMagick before 7.1.2-30 contains a time-of-check-time-of-use vulnerability in path policy enforcement on Windows that allows attackers to bypass read or write restrictions by exploiting symlink race conditions. Attackers can swap symlinks between policy validation and file access to read or write policy-denied files.
CVE-2026-63839				0.002		In the Linux kernel, the following vulnerability has been resolved: platform/x86: lenovo-wmi-helpers: Fix memory leak in lwmi_dev_evaluate_int() lwmi_dev_evaluate_int() leaks output.pointer when retval == NULL (found by sashiko.dev [1]). Fix it by moving `ret_obj = output.pointer' outside of the `if (retval)' block so that it is always freed by the __free cleanup callback. No functional change intended.
CVE-2026-80785				0.002		In the Linux kernel, the following vulnerability has been resolved: fbdev: serialize mode sysfs access with lock_fb_info() show_mode(), show_modes(), and store_mode() access fb_info->modelist and fb_info->mode without holding lock_fb_info(). store_modes() takes lock_fb_info() while replacing the modelist and freeing the old one. A concurrent reader or writer can load a pointer to an old modelist entry before st...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80786				0.002		In the Linux kernel, the following vulnerability has been resolved: fbdev: Wrap user-invoked calls to fb_set_var() in helper Handle fbcon during display updates in fb_set_var_from_user(). Check with fbcon if the mode change is possible, update hardware state and finally update fbcon. Update all callers. Only the FBIOPUT_VSCREENINFO ioctl currently does all steps. Other mode-changes callers in sysfs and driver c...
CVE-2026-80788				0.002		In the Linux kernel, the following vulnerability has been resolved: nvmet-tcp: Do not WARN on remotely-controlled oversized SGL allocations When fuzzing the nvme target code, I tripped a kernel warning in nvmet_tcp_map_data() because the length passed into the allocator is controlled by the remote initiator. A remote initiator that sends a command with an SGL claiming a huge number, can create a scatterlist and...
CVE-2026-80812				0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: dummy: Check card index validity at probe snd_dummy_probe() blindly trusts that the given devptr->id value is within the proper card index range. It's OK for the devices the driver itself creates at the module probe time, but if the device is bound manually via sysfs interface, this could be -1 as "none", and this leads to OOB access for ...
CVE-2026-80814				0.002		In the Linux kernel, the following vulnerability has been resolved: rndis_host: add overflow check in rndis_rx_fixup() Add an overflow check to ensure that data_offset + data_len + 8 does not wrap, which would enable an OOB read of the USB data buffer.
CVE-2026-80822				0.002		In the Linux kernel, the following vulnerability has been resolved: mailbox: mchp-ipc-sbi: Add null check for devm_kasprintf() Add a check to see if devm_kasprintf() is not NULL in mchp_ipc_get_cluster_aggr_irq(), returning -ENOMEM if the function failed.
CVE-2026-80830				0.002		In the Linux kernel, the following vulnerability has been resolved: usb: core: Add lock to usb_wakeup_notification() Add a spin lock to usb_wakeup notification to prevent a race condition with dereferencing freed memory. This could be hit by the xHCI driver as it calls this function from an IRQ and could race with the hub_disconnect() function, which properly grabs this lock to protect the state of the device.
CVE-2026-80833				0.002		In the Linux kernel, the following vulnerability has been resolved: crypto: sun8i-ss - Remove crypto_rng interface Since the crypto_rng interface for hardware PRNGs is unused and is redundant with hwrng and the actual Linux RNG, it's being phased out. Most drivers for it were already removed. Go ahead and remove the sun8i-ss support which is one of the only remaining ones. As usual for crypto_rng, this driver ...
CVE-2026-80834				0.002		In the Linux kernel, the following vulnerability has been resolved: crypto: sun8i-ce - Remove crypto_rng interface Since the crypto_rng interface for hardware PRNGs is unused and is redundant with hwrng and the actual Linux RNG, it's being phased out. Most drivers for it were already removed. Go ahead and remove the sun8i-ce support which is one of the only remaining ones. Note that the sun8i-ce support for hw...
CVE-2026-80857				0.002		In the Linux kernel, the following vulnerability has been resolved: fuse: wait for FR_FINISHED on abort_on_kill to prevent use-after-free The abort_on_kill path in request_wait_answer() calls fuse_abort_conn() and returns without waiting for FR_FINISHED. If fuse_dev_do_write() is concurrently processing the same request (FR_LOCKED set), the caller frees req->args while it is still being accessed, causing a use-...
CVE-2026-80883				0.002		In the Linux kernel, the following vulnerability has been resolved: drm/tegra: gr2d/gr3d: Initialize address register map before HOST1X client is registered The host1x_client_register() function is called just prior to register map initialization loop, making the device available to userspace. This may result in userspace attempting to submits a job before the register map is initialized. Address this by moving ...
CVE-2026-80899				0.001		In the Linux kernel, the following vulnerability has been resolved: erofs: remove fscache backend entirely EROFS over fscache was introduced to provide image lazy pulling functionality. After the feature landed, the fscache subsystem made netfs a new hard dependency, which is unexpected for a local filesystem and has an kernel-defined caching hierarchy which could be inflexible compared to the fanotify pre-conte...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80907				0.002		In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: Fix UVD dpb min size calculation for H264 This should use actual number of references from the decode message, instead of maximum derived from level. (cherry picked from commit 64b525edb7e7bdfcdc77883c5e413804e2396856)
CVE-2026-80908				0.002		In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: Reject UVD message with dimensions above 4096 Fixes potential overflow in DPB size calculations. (cherry picked from commit 05e1387d151f71569fbe122d2c89f9db0c21dc10)
CVE-2026-80909				0.002		In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: Reject UVD message with invalid number of h265 refs Same change as for h264, avoids overflow later when calculating min dpb size. (cherry picked from commit a4b0720e4f1601f97f59a2be9c1b4b94fa6527d5)

P3/P4 items (302) are in the Excel report. Unscored CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.